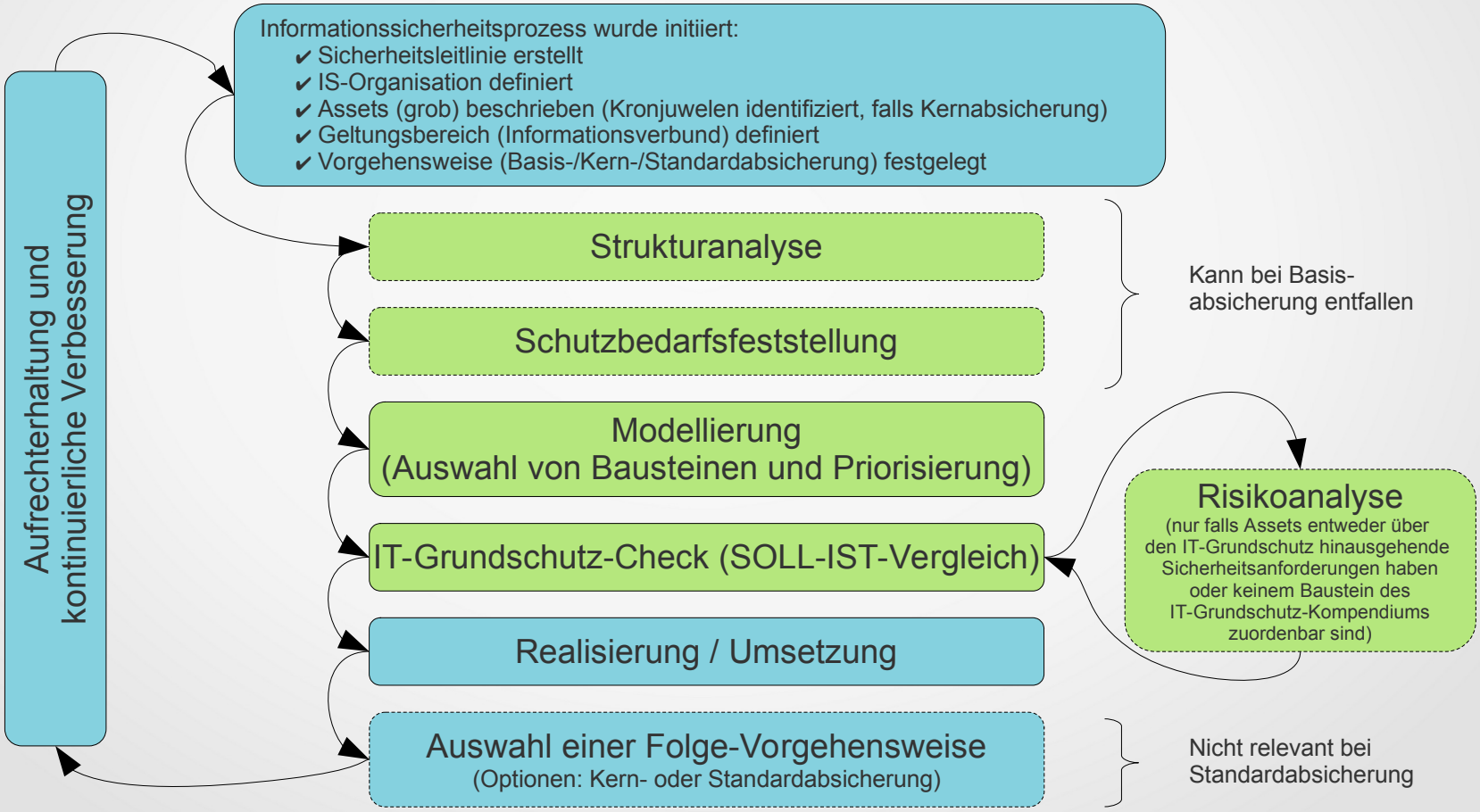
Management der Informationssicherheit

Teil2: Phase 4 des Sicherheitsprozesses nach BSI IT-Grundschutzmethodik

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 „Erstellung einer Sicherheitskonzeption“:**



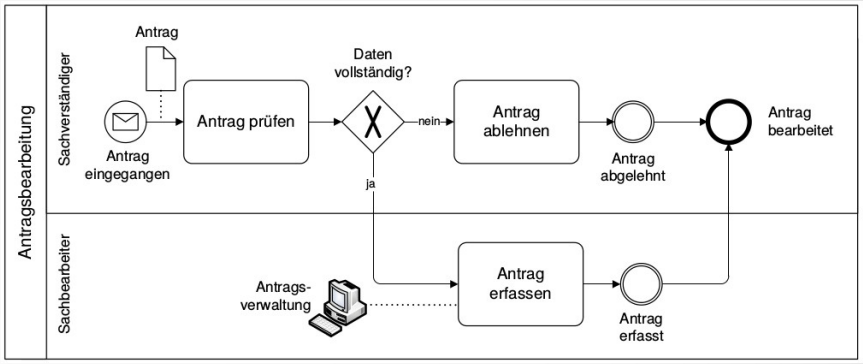
Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Strukturanalyse“:**
  - dient der **Vorerhebung von Informationen**, die **für** die weitere Vorgehensweise in der Erstellung eines **Sicherheitskonzepts** nach IT-Grundschutz benötigt werden und
  - Besteht aus der **Erfassung** der Bestandteile (**Geschäftsprozesse**, **Informationen**, **Anwendungen**, **IT-** und ICS[1)]- bzw IoT-**Systeme**, **Räume/Gebäude**, **Kommunikationsnetze**), die zur Betrachtung des Geltungsbereichs benötigt werden
    - Ähnliche Objekte sollten iS einer Komplexitätsreduktion dabei möglichst gruppiert werden (zB Clients [einer Abteilung])

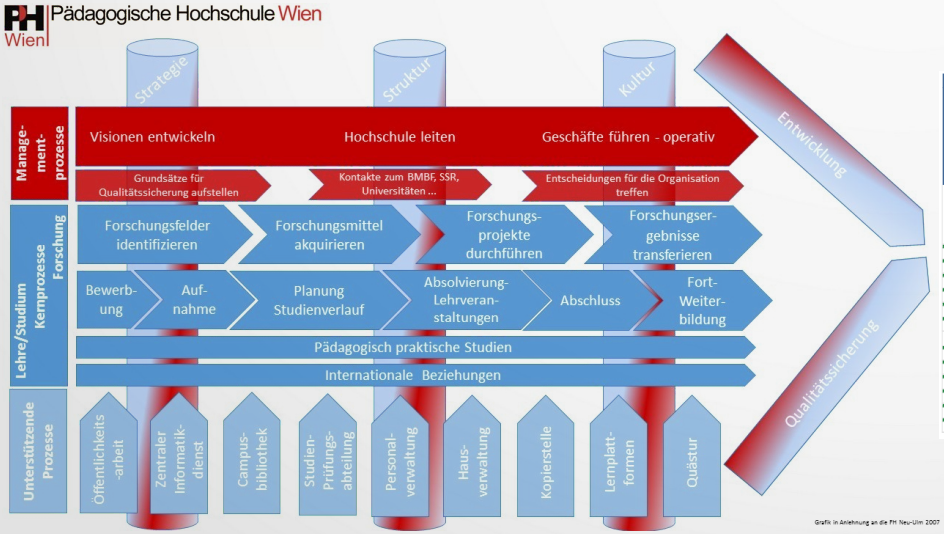
[1)] ICS … industrial control systems: beschreiben industrielle Steuerungssysteme wie sie bspw in Minen sowie bei der Öl-, Gas- und Kohleförderung ebenso wie in Fabriken, bei der Frisch- und Abwasseraufbereitung, in Kraftwerken, der Zellstoff- und Papierherstellung sowie in der Transport- und Logistikbranche eingesetzt werden und die zunehmend auch über öffentliche Schnittstellen bzw Netzzugänge verfügen und somit auch (leichter) angreifbar werden; Hier kommen typischerweise Technologien Distributed Control Systems (DCS), speicherprogrammierbare Steuerungen (SPS, auch Programmable Logic Controller, PLC) und Supervisory Control And Data Acquisition (SCADA) zum Einsatz

Informationssicherheitsmanagement

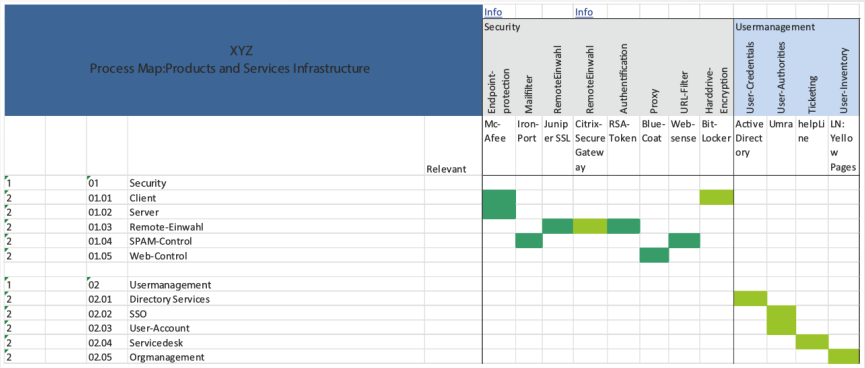
- **IS-Prozess – Phase#4 - Schritt „Strukturanalyse“:**
  - **Erfassung der Geschäftsprozesse**:
    - zB ausgehend von Prozesslandkarte
    - Beschreibung der Prozesse (zB anhand entsprechender Diagramme) inkl Verantwortlichkeiten sowie erforderlicher Applikationen, IT-Systeme, etc



BPMN-Diagramm zu Prozess „Antragsbearbeitung“



Prozesslandkarte der PH Wien



XYZ Process Map:Products and Services Infrastructure				Info								Info			
				Security								Usermanagement			
				Endpoint-protection	Mailfilter	RemoteEinwahl	RemoteEinwahl	Authentification	Proxy	URL-Filter	Harddrive-Encryption	User-Credentials	User-Authorities	Ticketing	User-Inventory
			Relevant	Mc-Afee	Iron-Port	Juniper SSL	Citrix-Secure Gateway	RSA-Token	Blue-Coat	Web-sense	Bit-Locker	Active Directory	Umra	helpLine	LN: Yellow Pages
1	01	Security													
2	01.01	Client		■							■				
2	01.02	Server		■											
2	01.03	Remote-Einwahl				■	■	■							
2	01.04	SPAM-Control			■					■					
2	01.05	Web-Control							■						
1	02	Usermanagement													
2	02.01	Directory Services										■			
2	02.02	SSO											■		
2	02.03	User-Account													
2	02.04	Servicedesk												■	
2	02.05	Orgmanagement													■

Produkt-Prozess-Matrix

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Strukturanalyse“:**

A.1 Geschäftsprozesse der RECPLAST GmbH				
Bezeichnung	**Beschreibung des Prozesses**	**Prozess-Art**	**Prozessverant-wortlicher**	**Mitarbeiter**
GP001	**Produktion:** Die Produktion der Kunststoffartikel umfasst alle Phasen von der Materialbereitstellung bis hin zur Einlagerung des produzierten Materials. Hierzu gehören innerhalb der Produktion die internen Transportwege, die Produktion und Fertigung der verschiedenen Komponenten und das Verpacken der Teile.	Kerngeschäft	Leiter Produktion	Alle Mitarbeiter
GP002	**Angebotswesen:** In der Angebotsabwicklung werden die Kundenanfragen für Produkte verarbeitet. Im Regelfall werden Kundenanfragen formlos per E-Mail oder Fax geschickt. Die Angebote werden elektronisch erfasst und ein schriftliches Angebot per Post an den Kunden versendet.	Unterstützender Prozess	Leiter Angebotswesen	Vertrieb
GP003	**Auftragsabwicklung:** Kunden schicken die Bestellungen im Regelfall per Fax oder E-Mail. Alle Belege müssen ausgedruckt und elektronisch erfasst werden. Eine Auftragsbestätigung erhält der Kunde nur, wenn er dies ausdrücklich wünscht oder der Produktionsprozess von der üblichen Produktionszeit abweicht.	Kerngeschäft	Leiter Auftrags-abwicklung	Vertrieb
GP004	**Einkaufsabteilung:** In der Einkaufsabteilung werden alle erforderlichen Artikel bestellt, die nicht für den Produktionsprozess erforderlich sind. In dieser Abteilung werden externe Projekte verhandelt, IT-Verträge gestaltet und Verbrauchsmaterial im organisatorischen Umfeld (Papier, Toner, etc.) beschafft.	Unterstützender Prozess	Leiter Einkaufsabteilung	Einkauf
GP005	**Disposition:** In der Disposition werden alle für die Produktion benötigten Materialien (Kunststoffe, Schrauben, Tüten, etc.) beschafft. Hierzu liegen normalerweise Rahmenverträge vor. Geplant wird in diesem Umfeld anhand von Jahresplanmengen und verschiedenen Bestellwerten.	Kerngeschäft	Leiter Disposition	Disposition, Produktion

Bsp: **Erfassung der Geschäfts-prozesse** (Bezeichnung, Beschreibung, Art [=Kern-/ Management-/ Support-Prozess], Verantwortlicher, Mitarbeiter/ Organisationseinheiten)

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Strukturanalyse“:**

Bsp: **Erfassung der Anwendungen** (Individual- und Standardanwendungen)

A.1 Strukturanalyse der RECPLAST GmbH

Bezeich-nung	Beschreibung des Ziel-objektes / der Gruppe der Zielobjekte	Plattform / Baustein	Ort	Gebäude	Raum	Anzahl	Status	Benutzer	Verantwortlich / Administrator
A003	**Textverarbeitung, Tabellenkalkulation:** Alle geschäftlichen Informationen werden in einem Office-Produkt verarbeitet, Geschäftsbriefe, Analysen oder Präsentationen	Office-Produkt 2010	-	-	-	130	in Betrieb	Alle Mitarbeiter	IT-Betrieb
A004	**Chat-Anwendung:** Eine Chat-Anwendung soll den Kontakt zwischen den Mitarbeitern vereinfachen. Die E-Mails werden standardmäßig nur zwei Mal pro Tag abgerufen. Diese Anwendung wird als virtualisierte Anwendung eingesetzt.	Standardsoft-ware	-	-	-	130	in Betrieb	Alle Mitarbeiter	IT-Betrieb
A008	**Active Directory:** Diese Anwendung soll dem IT-Betrieb die Arbeit erleichtern und doppelte Benutzereingaben reduzieren.	Active Directory	Bonn	BG	Büro	5	Test	Administrato-ren	IT-Betrieb

Abbildung 13: Auszug aus der Strukturanalyse der RECPLAST GmbH (Anwendungen)

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Strukturanalyse“:**

Bsp: **Zuordnung der Geschäftsprozesse zu den Anwendungen**

A.1 Zuordnungen Geschäftsprozesse zu Anwendungen der RECPLAST GmbH										
Geschäftsprozess / Anwendung	A001	A002	A003	A004	A005	A006	A007	A008	A009	A010
GP001	x					x	x			x
GP002					x	x	x		x	
GP003					x	x	x		x	
GP004			x	x		x	x	x	x	
GP005			x			x	x	x	x	

Abbildung 14: Zuordnung der Geschäftsprozesse zu den Anwendungen der RECPLAST GmbH

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Strukturanalyse“:**

Bsp: **Netzplanerhebung**

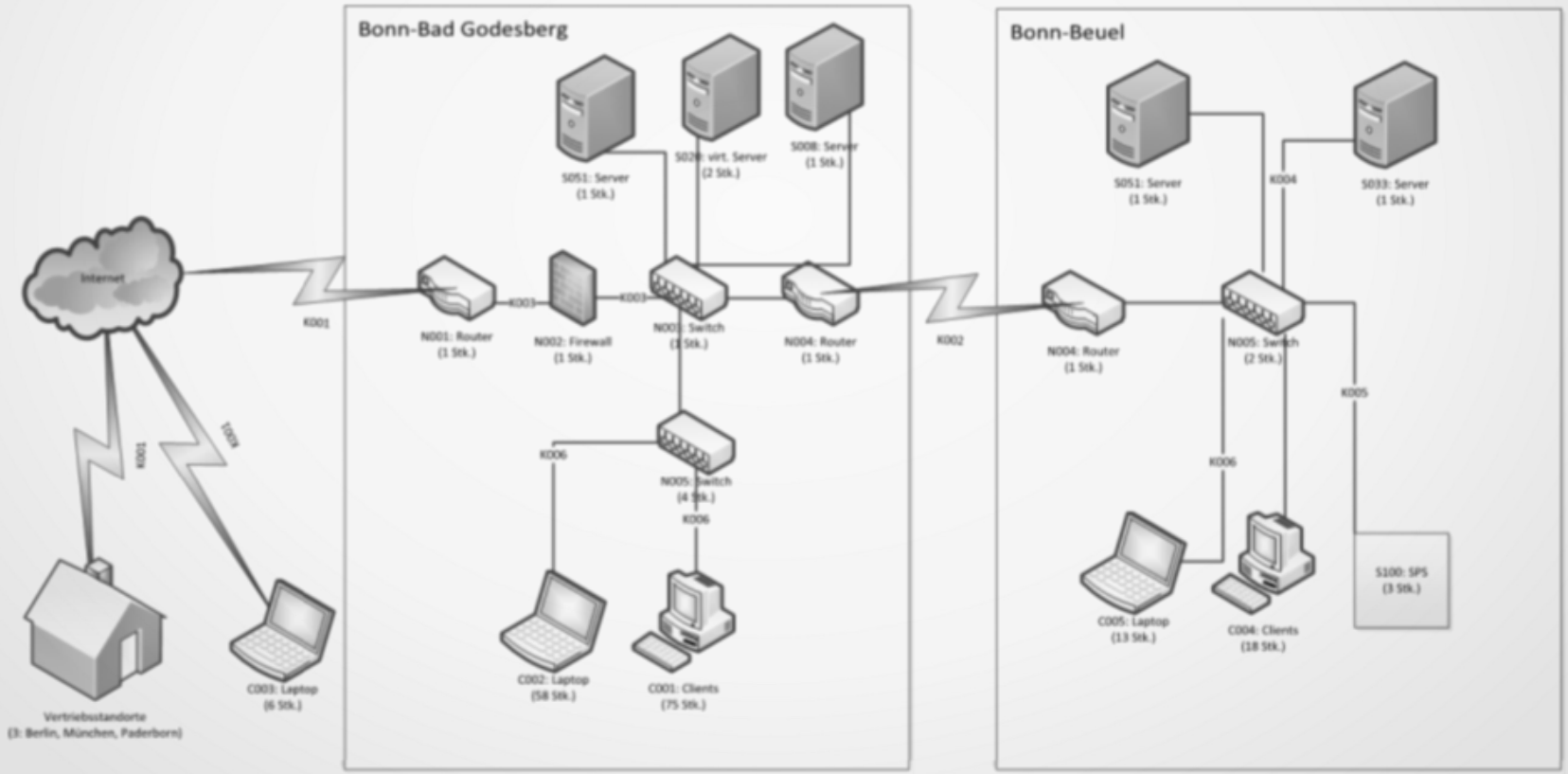


Abbildung 15: Auszug aus dem bereinigten Netzplan der RECPLAST GmbH (Teilausschnitt)

Informationssicherheitsmanagement

- IS-Prozess – Phase#4 - Schritt „Strukturanalyse“:

Bsp: Erhebung der IT-Systeme – ebenso muss eine Erhebung sonstiger Geräte (wie bspw Alarmanlagen, Videoüberwachung, IoT-/ICS-Geräte, ...) und Gebäude/Räume (Büros, Serverräume, Archive, mobile Arbeitsplätze, Kundenzonen, ...) erfolgen

A.1 Strukturanalyse der RECPLAST GmbH

Bezeichnung	Beschreibung des Zielobjektes / der Gruppe der Zielobjekte	Plattform / Baustein	Ort	Gebäude	Raum	Anzahl	Status	Benutzer	Verantwortlich / Administrator
N001	**Router Internetanbindung:** Dieser Router regelt die Kommunikation zwischen dem Internet und den internen Prozessen	Router und Switches	Bonn	BG	Serverraum	1	in Betrieb	Administratoren	IT-Betrieb
N002	**Firewall Internet-Eingang:** Diese Firewall dient als Schutz zwischen dem Internet und dem internen Netz	Firewall	Bonn	BG	Serverraum	1	in Betrieb	Administratoren	IT-Betrieb
N003	**Switch – Verteilung** Der Datenfluss in Richtung Internet und internes Netz wird über den Switch gesteuert	Router und Switches	Bonn	BG	Serverraum	1	in Betrieb	Administratoren	IT-Betrieb
N004	**Router Bonn BG – Beuel** Über eine Standleitung sind die beiden Standorte in Bonn verbunden. Diese Router sichern die Verbindung ab.	Router und Switches	Bonn	-	Serverraum	2	in Betrieb	Administratoren	IT-Betrieb
S008	**Print-Server:** Server für die Druckerdienste, die zentral gesteuert werden.	Windows Server 2012	Bonn	BG	Serverraum	1	in Betrieb	Alle Mitarbeiter	IT-Betrieb
S020	**Virtueller Server (Konfiguration 1):** Auf dem Server können bis zu 20 virtuelle Server konfiguriert werden. Für die Verwaltung der virtualisierten Systeme wird eine Anwendung eingesetzt.	Server unter Unix	Bonn	BG	Serverraum	2	in Betrieb	Administratoren	IT-Betrieb
S033	**Server Produktion:** Die zentralen Daten für die Produktion werden auf diesem Server verarbeitet.	Server unter Unix	Bonn	Beuel	Serverraum	1	in Betrieb	Mitarbeiter Produktion	IT-Betrieb

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Schutzbedarfsfeststellung“:**
  - Ziel der Schutzbedarfsfeststellung ist es, für die erfassten Objekte im Informationsverbund zu entscheiden, welchen **Schutzbedarf** sie bezüglich Vertraulichkeit, Integrität und Verfügbarkeit (sowie der weiteren Schutzziele) besitzen
  - Der Schutzbedarf orientiert sich an den möglichen Schäden, die mit einer Beeinträchtigung der betroffenen Anwendungen und damit der jeweiligen Geschäftsprozesse verbunden sind – typische **Schadensszenarien** sind:
    - **Verstoß gegen Gesetze/Vorschriften/Verträge** (zB DSGVO, Urheberrecht, TKG, EgovG, … ebenso wie Dienstleistungsverträge),
    - **Beeinträchtigung des informationellen Selbstbestimmungsrechts** (zB unzulässige Erhebung personenbezogener Daten ohne Rechtsgrundlage oder Einwilligung oder unbefugte Weitergabe personenbezogener Daten, usw),
    - **Beeinträchtigung der persönlichen Unversehrtheit** (zB iZshg mit medizinischen Überwachungsrechnern/Diagnosesystemen, Flugkontrollrechnern, Verkehrsleitsystemen, usw),
    - **Beeinträchtigung der Aufgabenerfüllung** (zB Fristversäumnisse durch verzögerte Bearbeitung von Verwaltungsvorgängen, verspätete Lieferung aufgrund verzögerter Bearbeitung von Bestellungen, fehlerhafte Produktion aufgrund falscher Steuerungsdaten, unzureichende Qualitätssicherung durch Ausfall eines Testsystems, usw),
    - **negative Innen- oder Außenwirkung** (Ansehens-/Vertrauensverlust, Demoralisierung der Mitarbeiter, Beeinträchtigung der wirtschaftlichen Beziehungen zusammenarbeitender Institutionen, Einbüßen der Konkurrenzfähigkeit, usw) und
    - **finanzielle Auswirkungen** (unerlaubte Weitergabe von Forschungs- und Entwicklungsergebnissen, Manipulation von finanzwirksamen Daten in einem Abrechnungssystem, Ausfall eines IT-gesteuerten Produktionssystems und dadurch bedingte Umsatzverluste, unerlaubte Einsichtnahme in Marketingstrategiepapiere oder Umsatzzahlen, Ausfall eines Buchungssystems einer Reisegesellschaft, Ausfall eines E-Commerce-Servers, Zusammenbruch des Zahlungsverkehrs einer Bank, Diebstahl oder Zerstörung von Hardware, usw)

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Schutzbedarfsfeststellung“:**
  - Nach der **Definition der Schutzbedarfskategorien**
    - Schadensauswirkungen sind begrenzt und überschaubar => **normal** (abgedeckt durch Standardabsicherung)
      - *"Der mögliche finanzielle Schaden ist kleiner als 50.000 Euro."*
      - *"Die Abläufe bei RECPLAST werden allenfalls unerheblich beeinträchtigt. Ausfallzeiten von mehr als 24 Stunden können hingenommen werden."*
    - Schadensauswirkungen können beträchtlich sein => ***hoch*** (geht über Standardabsicherung hinaus, erfordert eigenständige/zusätzliche Risikoanalyse)
      - *"Der mögliche finanzielle Schaden liegt zwischen 50.000 und 500.000 Euro."*
      - *"Die Abläufe bei RECPLAST werden erheblich beeinträchtigt. Ausfallzeiten dürfen maximal 24 Stunden betragen."*
    - Schadensauswirkungen können ein existentiell bedrohliches, katastrophales Ausmaß erreichen => ***sehr hoch***
      - *"Der mögliche finanzielle Schaden liegt über 500.000 Euro."*
      - *"Die Abläufe bei RECPLAST werden so stark beeinträchtigt, dass Ausfallzeiten, die über zwei Stunden hinausgehen, nicht toleriert werden können."*

  wird anhand der oben genannten typischen Schadensszenarien zunächst der **Schutzbedarf der Geschäftsprozesse und Anwendungen** bestimmt - Anschließend wird daraus der **Schutzbedarf der einzelnen IT-Systeme, Räume und Kommunikationsverbindungen** nach einem der drei folgenden Prinzipien abgeleitet bzw **vererbt**

  - **Maximumprinzip**: Schutzbedarf ergibt sich aus dem höchsten Schutzbedarf aller Geschäftsprozesse/Anwendungen, die das IT-System benötigen
  - **Kumulationsprinzip/-effekt**: Der Schutzbedarf des IT-Systems kann höher sein als der Schutzbedarf der einzelnen Geschäftsprozesse/Anwendungen. Dies ist z. B. dann der Fall, wenn auf einem Server mehrere Anwendungen mit mittlerem Schutzbedarf in Betrieb sind. Der Ausfall einer dieser Anwendungen könnte überbrückt werden. Wenn aber alle Anwendungen gleichzeitig ausfallen, kann ein hoher Schaden entstehen.
  - **Verteilungseffekt**: Der Schutzbedarf kann niedriger sein als der Schutzbedarf der zugeordneten Anwendungen, wenn eine Anwendung mit hohem Schutzbedarf auf mehrere Systeme verteilt ist (zB bei redundanten Systemen aber auch durch Pseudonymisierung)

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Schutzbedarfsfeststellung“:**

A.2 Schutzbedarfsfeststellung der RECPLAST GmbH

Bezeichnung	Beschreibung des Zielobjektes / der Gruppe der Zielobjekte	Plattform / Baustein	Verantwortlich / Administrator	Vertraulichkeit	Begründung für die Vertraulichkeit	Integrität	Begründung für die Integrität	Verfügbarkeit	Begründung für die Verfügbarkeit
A003	Textverarbeitung, Tabellenkalkulation	Office-Produkt 2010	IT-Betrieb	normal	Die Anwendung selbst enthält keine Informationen.	normal	Die Anwendung selbst enthält keine Informationen	normal	Die Anwendung wird lokal installiert. Die Lizenzen sind entsprechend aufgehoben, so dass eine Neuinstallation schnell ermöglicht werden kann. Eine Ausfallzeit von mehr als 24 Stunden ist tolerierbar.
A007	Lotus Notes	Lotus Notes	IT-Betrieb	hoch	Über das E-Mailsystem werden viele, teilweise vertrauliche Informationen versendet. Durch die Anwendung werden alle E-Mails verschlüsselt.	normal	Durch eine Signatur kann die Integrität einer E-Mail festgestellt werden.	sehr hoch	Das Mailsystem sollte auch dann zur Verfügung stehen, falls andere Kommunikationsmittel ausfallen (z.B. Faxserver)
C002	Laptop Verwaltung	Client unter Windows 10	IT-Betrieb	normal	Maximumprinzip Auf dem Arbeitsplatzrechner werden keine Informationen gespeichert	normal	Maximumprinzip Auf dem Arbeitsplatzrechner werden keine Informationen gespeichert	normal	Es ist ein Ausfall von höchstens 4 Stunden tolerierbar.

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Schutzbedarfsfeststellung“:**

A.2 Schutzbedarfsfeststellung der RECPLAST GmbH

Bezeichnung	Beschreibung des Zielobjektes / der Gruppe der Zielobjekte	Plattform / Baustein	Vertraulichkeit	Begründung für die Vertraulichkeit	Integrität	Begründung für die Integrität	Verfügbarkeit	Begründung für die Verfügbarkeit
N001	Router Internetanbindung	Router und Switches	hoch	Zutritt, Zugang und Zugriff nur für autorisierte Personen möglich	normal	Zutritt, Zugang und Zugriff nur für autorisierte Personen möglich	normal	Ersatzgerät liegt auf Lager und kann schnell durch den IT-Betrieb ausgetauscht werden
N002	Firewall Internet-Eingang	Firewall	hoch	Die Konfigurationseigenschaften müssen vertraulich bleiben. Diese regeln den Datenverkehr zwischen dem Internet und der RECPLAST	normal	Zutritt, Zugang und Zugriff nur für autorisierte Personen möglich	normal	Ersatzgerät liegt auf Lager und kann schnell durch den IT-Betrieb ausgetauscht werden
N003	Switch – Verteilung	Router und Switches	normal	Zutritt, Zugang und Zugriff nur für autorisierte Personen möglich	normal	Zutritt, Zugang und Zugriff nur für autorisierte Personen möglich	normal	Ersatzgerät liegt auf Lager und kann schnell durch den IT-Betrieb ausgetauscht werden
N004	Router Bonn BG – Beuel	Router und Switches	normal	Die Konfigurationseigenschaften müssen vertraulich bleiben. Diese regeln den Datenverkehr zwischen den Standorten der RECPLAST	normal	Zutritt, Zugang und Zugriff nur für autorisierte Personen möglich	normal	Ersatzgerät liegt auf Lager und kann schnell durch den IT-Betrieb ausgetauscht werden

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Schutzbedarfsfeststellung“:**

A.2 Schutzbedarfsfeststellung der RECPLAST GmbH

Bezeichnung	Beschreibung des Zielobjektes / der Gruppe der Zielobjekte	Plattform / Baustein	Vertraulichkeit	Begründung für die Vertraulichkeit	Integrität	Begründung für die Integrität	Verfügbarkeit	Begründung für die Verfügbarkeit
S008	Print-Server	Windows Server 2012	normal	Es werden keine vertraulichen Dokumente ausgedruckt.	normal	Fehlfunktionen werden durch ein Monitoring schnell erkannt, gemeldet und können sofort behoben werden	normal	Kann schnell auf einem anderen virtuellen Server installiert werden.
S020	Virtueller Server (Konfiguration 1)	Server unter Unix	normal	Die Server sind im eigenen Serverraum mit Zugriff-, Zugangs- und Zutrittsberechtigung untergebracht.	normal	Die Server sind im eigenen Serverraum mit Zugriff-, Zugangs- und Zutrittsberechtigung untergebracht.	normal	Durch die Redundanz der Server kann bei Ausfall eines Servers der Dienst von einem anderen Server übernommen werden.
S033	Server Produktion	Server unter Unix	sehr hoch	Die verarbeiteten Informationen sind für die Produktion notwendig. Insbesondere werden Stücklisten, Arbeitspläne und weitere Informationen zum Produktionsprozess auf diesem Server in einer Datenbank gespeichert.	hoch	Die Informationen auf dem Server müssen für den produzierenden Bereich vollständig und korrekt vorliegen. Insbesondere Stücklisten und Arbeitspläne dürfen nicht unbeachtet verändert werden.	sehr hoch	Der Server muss zu allen Produktionszeiten (täglich 6 – 22 Uhr) zur Verfügung stehen. Einen Ersatz-Server gibt es nicht. Wartungsarbeiten werden grundsätzlich am Wochenende vorgenommen.

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Schutzbedarfsfeststellung“:**
  - Einrichtung von **Sicherheitszonen** um dem Maximumprinzip entgegenzuwirken und Informationssicherheit wirtschaftlich angemessen realisieren zu können – Bsp:
    - **Räumliche Sicherheitszonen**: Um nicht jeden einzelnen Büroraum permanent abschließen oder überwachen zu müssen, sollten Zonen mit starkem Besucherverkehr von hochschutzbedürftigen Bereichen getrennt werden. So sollten sich Besprechungs-, Schulungs- oder Veranstaltungsräume ebenso wie eine Kantine, die externes Publikum anzieht, in der Nähe des Gebäudeeingangs befinden. Der Zugang zu Gebäudeteilen mit Büros kann dann von einem Portier einfach überwacht werden. Besonders sensitive Bereiche wie eine Entwicklungsabteilung sollten mit einer zusätzlichen Zugangskontrolle, zB über Chipkarten, abgesichert werden.
    - **Technische Sicherheitszonen**: Um vertrauliche Daten auf bestimmte Bereiche innerhalb eines LANs zu begrenzen und um zu verhindern, dass Störungen in bestimmten Komponenten oder Angriffe die Funktionsfähigkeit beeinträchtigen, ist es hilfreich, das LAN in mehrere Teilnetze aufzuteilen (s Baustein NET.1.1)
    - **Personelle Sicherheitszonen**: Grundsätzlich sollten an jede Person immer nur so viele Rechte vergeben werden, wie es für die Aufgabenwahrnehmung erforderlich ist. Darüber hinaus gibt es auch verschiedene Rollen, die eine Person nicht gleichzeitig wahrnehmen sollte. So sollte ein Revisor nicht gleichzeitig in der Buchhaltung und in der IT-Administration arbeiten, da er sich nicht selbst kontrollieren kann und darf. Um die Vergabe von Zugangs- und Zutrittsrechte zu vereinfachen, sollten Personengruppen, die nicht miteinander vereinbare Funktionen wahrnehmen, in getrennten Gruppen oder Abteilungen arbeiten.

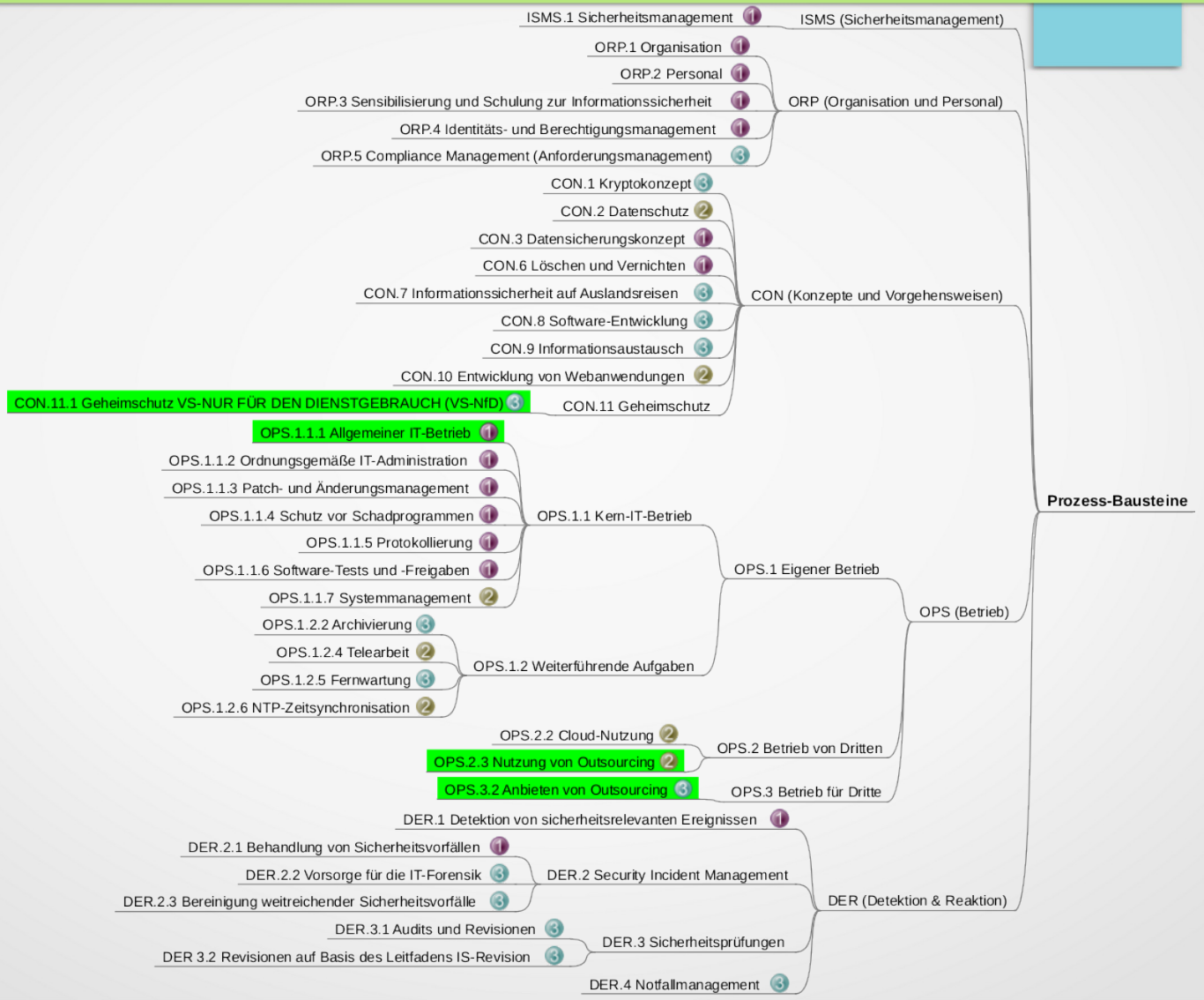
Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Modellierung“:**
  - Nachdem die notwendigen Informationen aus der Strukturanalyse und der Schutzbedarfsfeststellung vorliegen, besteht der nächste Schritt darin, den betrachteten Informationsverbund mithilfe der vorhandenen **Bausteine** (unterteilt in Prozess- und Systembausteine) aus dem **IT-Grundschutz-Kompendium** (IT-GSK) nachzubilden
    - Das IT-GSK wird laufend aktualisiert und erweitert
  - Das Ergebnis ist ein **IT-Grundschutz-Modell** des Informationsverbunds, das aus verschiedenen (gegebenenfalls auch mehrfach verwendeten[1)]) Bausteinen besteht
    - Falls für einen Bereich des Informationsverbunds kein passender Baustein gefunden werden kann, muss eine eigene zusätzliche Risikoanalyse erfolgen
  - Das IT-Grundschutz-Modell eines **bereits realisierten Informationsverbunds** identifiziert über die verwendeten Bausteine die relevanten Sicherheitsanforderungen und kann in Form eines **Prüfplan**s benutzt werden, um einen **Soll-Ist-Vergleich** durchzuführen.
  - Das IT-Grundschutz-Modell eines **geplanten Informationsverbunds** stellt hingegen ein **Entwicklungskonzept** dar. Es beschreibt über die ausgewählten Bausteine, welche Sicherheitsanforderungen bei der Realisierung des Informationsverbunds erfüllt werden müssen.

[1)] Wenn Teile des vorliegenden Informationsverbunds verschiedenen Organisationseinheiten zugeordnet sind und anderen Rahmenbedingungen unterliegen, sollten bspw die Baustein ORP.1 (Organisation) und ORP.2 (Personal) auf jede Organisationseinheit getrennt angewandt werden.

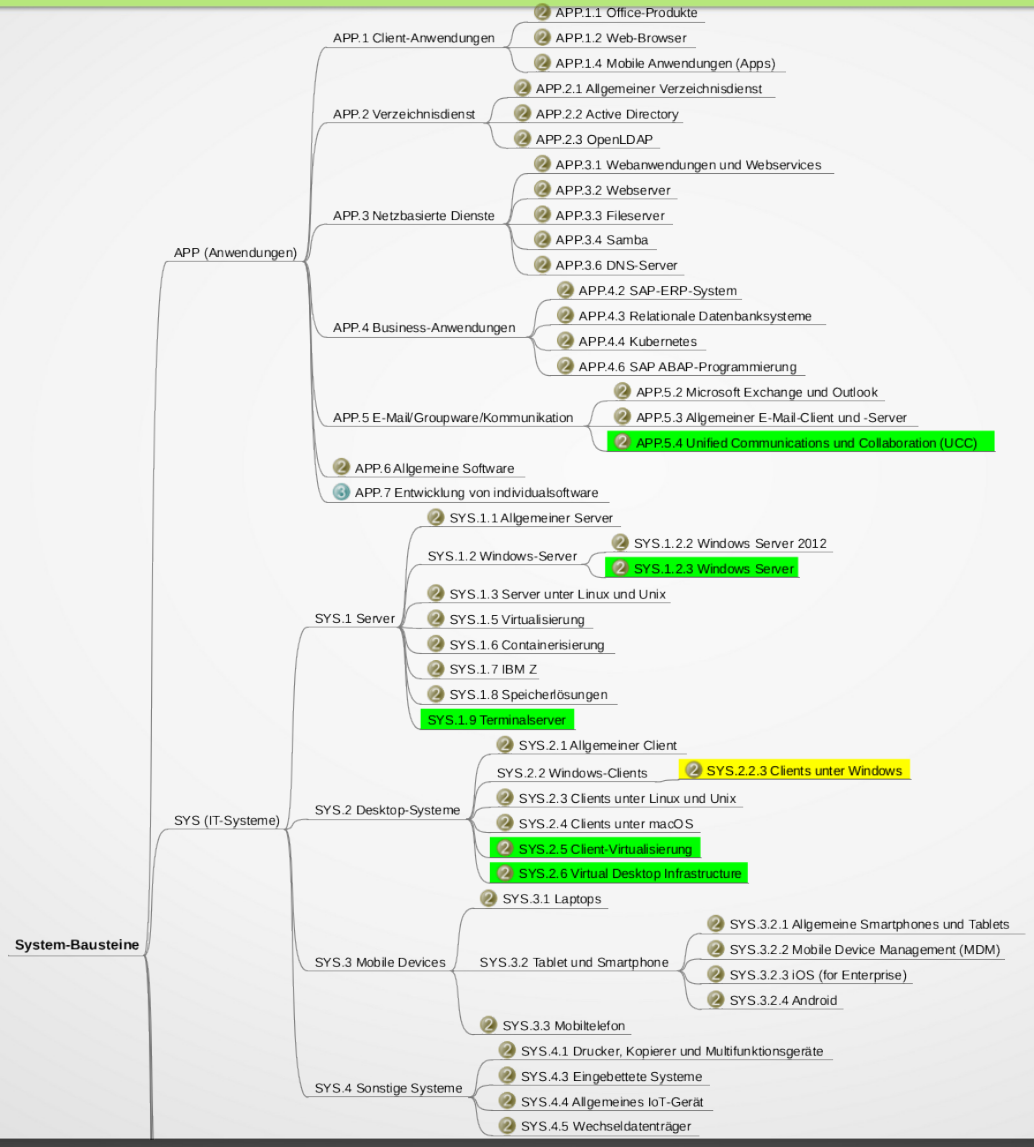
Informationssicherheitsmanagement

Phase#4 – Schritt „Modellierung“: Prozess-Bausteine des IT-GSK



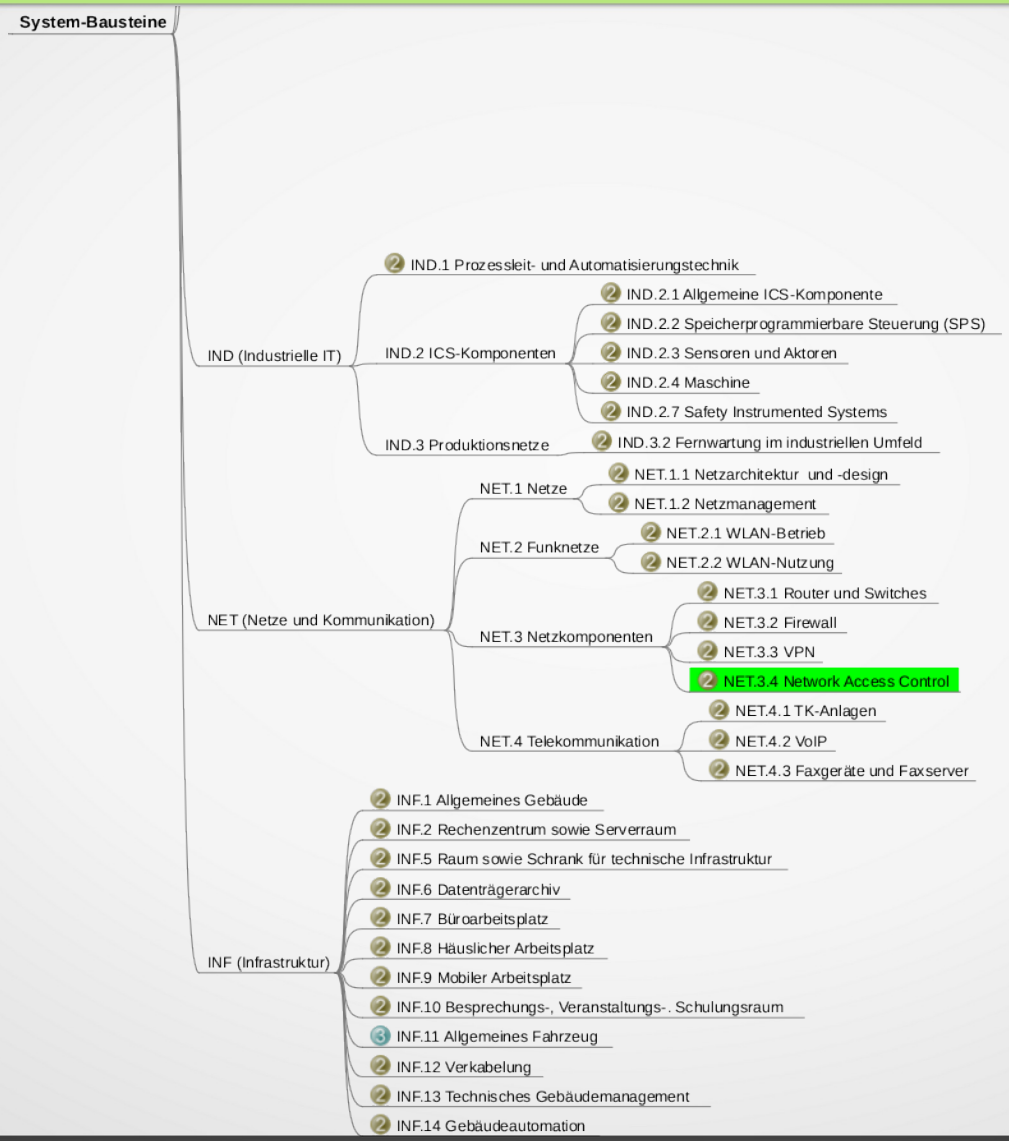
Informationssicherheitsmanagement

Phase#4 – Schritt „Modellierung“: System-Bausteine des IT-GSK



Informationssicherheitsmanagement

Phase#4 – Schritt „Modellierung“: System-Bausteine des IT-GSK



Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Modellierung“:**
  - **Für jeden Baustein wurde** im IT-GSK bereits eine entsprechende **Risikobeurteilung** (Gefährdungen, Eintrittswahrscheinlichkeit / Schadensausmaß) **durchgeführt** (und daraus die Sicherheitsanforderungen [und tlw auch Umsetzungsmaßnahmen] abgeleitet) => schnellere Umsetzung von IS-Maßnahmen
  - **Bausteine sind folgendermaßen strukturiert**:
    - Beschreibung des Zielobjekts
    - Zielsetzungen (=Sicherheitsgewinn bei Umsetzung)
    - Abgrenzungen / Verweise
    - **Spezifische Gefährdungen** (abgeleitet von elementaren Gefährdungen)
    - Anforderungen zur Erreichung der einzelnen **Schutzniveau**s (Basis/Standard/erhöht)
      - Prüfaspekte in den Anforderungen werden den **Modalverben MUSS und SOLLTE** sowie den zugehörigen Verneinungen formuliert, um die jeweiligen Anforderungen eindeutig zu kennzeichnen:
        - *MUSS/DARF NUR*: bedeutet, dass eine Anforderung unbedingt erfüllt werden muss (eine solche Anforderung kann bspw nicht im Rahmen der Risikoanalyse ohne Weiteres ignoriert werden)
        - *DARF NICHT*: bedeutet, dass etwas in keinem Fall getan werden darf.
        - *SOLLTE*: bedeutet, dass etwas normalerweise getan werden sollte, es aber Gründe geben kann, dies nicht zu tun. Dies muss aber sorgfältig abgewogen und begründet werden und die Begründung muss bei einem Audit vom Auditor auf ihre Stichhaltigkeit geprüft werden.
        - *SOLLTE NICHT/SOLLTE KEIN*: bedeutet, dass etwas normalerweise nicht getan werden sollte, es aber Gründe gibt, dies doch zu tun. Dies muss aber sorgfältig abgewogen und begründet werden und und die Begründung muss bei einem Audit vom Auditor auf ihre Stichhaltigkeit geprüft werden.
    - **Kreuzreferenztabelle** (=Matrix zur Darstellung der Zusammenhänge zw Anforderungen und elementaren Gefährdungen) => möglicher Ausgangspunkt für vertiefte Risikoanalyse

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Modellierung“:**
  - Um grundlegende Risiken abzudecken und eine ganzheitliche Informationssicherheit aufzubauen, müssen die essenziellen Sicherheitsanforderungen frühzeitig erfüllt und entsprechende Sicherheitsmaßnahmen umgesetzt werden => (vom IT-Grundschutz vorgeschlagene) **Reihenfolge für die umzusetzenden Bausteine**:
    - **R1**: Diese Bausteine sollten vorrangig umgesetzt werden, da sie die Grundlage für einen effektiven Sicherheitsprozess bilden – dazu zählen:
      - ISMS Managementsysteme für Informationssicherheit
      - ORP Organisation und Personal
      - OPS.1.1 Kern-IT-Betrieb
    - **R2**: Diese Bausteine sollten als Nächstes umgesetzt werden, da sie in wesentlichen Teilen des Informationsverbunds für nachhaltige Sicherheit erforderlich sind
    - **R3**: Diese Bausteine werden zur Erreichung des angestrebten Sicherheitsniveaus ebenfalls benötigt und müssen umgesetzt werden, es wird aber empfohlen, diese erst nach den anderen Bausteinen zu betrachten

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Modellierung“:**

A.3 Modellierung der RECPLAST GmbH				
Nummer und Titel des Bausteins	**Rele-vanz**	**Zielobjekt**	**Begründung**	**Ansprech-partner**
APP.5.2 Microsoft Exchange / Outlook	nein		Wird nicht eingesetzt.	
APP 3.6 DNS-Server	ja	S019		
Benutzerdef.BS.1 PC für die Industrie-steuerung	ja	C005		
CON.7: Informationssicherheit auf Auslandsreisen	nein		Auslandsreisen sind für Informationsverbund nicht relevant.	
INF.1 Allgemeines Gebäude	ja	G001		
INF.7 Datenträgerarchiv	nein		Es gibt kein Datenträ-gerarchiv.	
INF.4 IT-Verkabelung	ja	Informations-verbund		
ISMS.1 (Sicherheitsmanagement)	ja	Informations-verbund		
NET.1.1 Netz-Architektur und -design	ja	Informations-verbund		
NET.3.1 Router und Switches	ja	S033		
OPS.1.1.2 Ordnungsgemäße IT-Admi-nistration	nein		Die IT-Administration findet außerhalb des Informationsverbun-des statt.	
OPS.2.4 Fernwartung	ja	Informations-verbund		
SYS.1.3 Server unter Unix	ja	S020		
SYS.4.1 Drucker, Kopierer und Multi-funktionsgeräte	ja	S048		

Auszug einer beispielhaften **Zuordnung von Bausteinen zu Zielobjekten** (=Objekte, die in der Strukturanalyse identifiziert wurden)

Dabei sollten grundsätzlich alle **Bausteine** (um keinen zu vergessen) angeführt werden und deren **Relevanz** für den abzusichernden Informations-verbund in einer eigenen Spalte ausgewiesen werden.

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „IT-Grundschutz-Check“:**
  - Organisatorische Vorarbeiten:
    - Hausinterne Dokumente mit Verfügungen und Regelungen sichten und Zuständigkeiten für diese Unterlagen klären
    - Feststellen, in welchem Umfang externe Stellen beteiligt werden müssen
    - **Hauptansprechpartner für jeden** in der Modellierung angewandten **Baustein** festlegen
    - **Terminplan und Teams für Interviews** zur Durchführung des SOLL-IST-Vergleichs abstimmen
  - **Durchführung SOLL-IST-Vergleich** = Sicherheitsanforderungen des jeweiligen Bausteins, für den die Interviewpartner zuständig sind, der Reihe nach durcharbeiten => **Umsetzungsstatus der einzelnen Anforderungen**:
    - **„entbehrlich“**: Die Erfüllung der Anforderung ist in der vorgeschlagenen Art nicht notwendig, weil die Anforderung im betrachteten Informationsverbund nicht relevant ist (zB weil Dienste nicht aktiviert wurden) oder durch Alternativmaßnahmen behandelt wurde[1)]
    - **„ja“**: Zu der Anforderung wurden geeignete Maßnahmen vollständig, wirksam und angemessen umgesetzt
    - **„teilweise“**: Die Anforderung wurde nur teilweise umgesetzt
    - **„nein“**: Die Anforderung wurde noch nicht erfüllt, also geeignete Maßnahmen sind größtenteils noch nicht umgesetzt

[1)] Wird der Umsetzungsstatus einer Anforderung auf „entbehrlich“ gesetzt, müssen über die Kreuzreferenztabelle des jeweiligen Bausteins die zugehörigen elementaren Gefährdungen identifiziert werden. Wurden Alternativmaßnahmen ergriffen, muss begründet werden, dass das Risiko, das von allen betreffenden elementaren Gefährdungen ausgeht, angemessen minimiert wurde. Generell ist zu beachten, dass bei Basis-Anforderungen das entstehende Risiko nicht übernommen werden kann. Anforderungen dürfen nicht auf „entbehrlich“ gesetzt werden, wenn das Risiko für eine im Baustein identifizierte elementare Gefährdung über die Kreuzreferenztabelle pauschal akzeptiert oder ausgeschlossen wird.

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „IT-Grundschutz-Check“:**

Dokumentation des SOLL-IST-Vergleichs als Ergebnis der durchgeführten Interviews (inkl Umsetzungshinweisen wie Verantwortlicher, Termin, Kostenschätzungen, Defizite, …)

A.4 IT-Grundschutz-Check der RECPLAST GmbH

Baustein:	**Sicherheitsmanagement**			
Anforderung	**Anforderungstitel**	**Verantwortung**	**Status**	**Umsetzung**
ISMS.1.A1	Übernahme der Gesamtverantwortung für Informationssicherheit durch die Leitungsebene	Institutionsleitung	umgesetzt	Die Geschäftsführung hat die Erstellung der Leitlinie initiiert. Die Leitlinie wurde von der Geschäftsführung unterzeichnet. Die Geschäftsführung hat die gesamte Verantwortung für das Thema Informationssicherheit übernommen und delegiert an den ISB die Umsetzung der geforderten Maßnahmen. Einmal monatlich erhält die Geschäftsführung einen Management-Report, kontrolliert den Umsetzungsstatus der Maßnahmen und initiiert ggf. weitere Maßnahmen und bewilligt das entsprechende Budget.
ISMS.1.A5	Vertragsgestaltung bei Bestellung eines externen Informationssicherheitsbeauftragten	Institutionsleitung	entbehrlich	Der Informationssicherheitsbeauftragte ist ein interner Mitarbeiter der RECPLAST GmbH.
ISMS.1.A7	Festlegung von Sicherheitsmaßnahmen	ISB	teilweise	Alle Mitarbeiter, die Maßnahmen im Sinne der Informationssicherheit umsetzen, sind verpflichtet, diese zu dokumentieren und dem ISB per E-Mail zuzusenden. Eine Auswertung und ausreichende Dokumentation der eingehenden umgesetzten Maßnahmen gibt es nicht. Umsetzungszeitpunkt für ausführliche Dokumentation: 30.04.
ISMS.1.A11	Aufrechterhaltung der Informationssicherheit	ISB	umgesetzt	Alle Dokumente und Prozesse werden einmal jährlich einem internen Audit unterzogen. Der ISB hat dafür die entsprechende fachliche Weisungsbefugnis für die Mitarbeiter, in deren Verantwortungsbereich einzelne Dokumente und Prozesse fallen.

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Risikoanalyse“:**
  - 2-stufiger Ansatz im IT-Grundschutz:
    - **„implizite Risikobewertung“**: bei der Erstellung der Bausteine des IT-GSK wird bereits implizit eine Risikobewertung für Bereiche mit normalem Schutzbedarf durchgeführt
      - Hierbei werden nur solche Gefährdungen betrachtet, die nach sorgfältiger Analyse eine so hohe Eintrittswahrscheinlichkeit oder so einschneidende Auswirkungen haben, dass Sicherheitsmaßnahmen ergriffen werden müssen
      - Typische Gefährdungen, gegen die sich jeder schützen muss, sind z. B. Schäden durch Feuer, Einbrecher, Schadsoftware oder Hardware-Defekte
      - Dieser Ansatz hat den Vorteil, dass Anwender des IT-Grundschutzes für einen Großteil des Informationsverbundes keine individuelle Bedrohungs- und Schwachstellenanalyse durchführen müssen, weil diese Bewertung vorab bereits vorgenommen wurde
    - **„explizite Risikobewertung“**: notwendig, falls der betrachtete Informationsverbund Zielobjekte enthält, die
      - einen *hohen* oder *sehr hohen* Schutzbedarf in mindestens einem der drei Grundwerte Vertraulichkeit, Integrität oder Verfügbarkeit haben oder
      - mit den existierenden Bausteinen des IT-Grundschutzes nicht hinreichend abgebildet (modelliert) werden können oder
      - in Einsatzszenarien (Umgebung, Anwendung) betrieben werden, die im Rahmen des IT-Grundschutzes nicht vorgesehen sind

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 - Schritt „Risikoanalyse“:**
  - Die **„explizite Risikobewertung“** ist im BSI-Standard 200-3 detailliert beschrieben und umfasst ua folgende Schritte:
    - **Erstellung der Gefährdungsübersicht**: In diesem Arbeitsschritt wird für jedes zu analysierende Zielobjekt eine Liste der jeweils relevanten Gefährdungen (ausgehend von elementaren hin zu möglichen/zusätzlichen) zusammengestellt (zB mittels Brainstorming)
    - **Risikoeinstufung:** Hier erfolgt zunächst eine Einschätzung der Eintrittswahrscheinlichkeit und des möglichen Schadensausmaßes => daraus folgt eine qualitative und quantitative Risikobewertung
    - **Behandlung von Risiken:** ist grundsätzlich abhängig vom Risikoappetit (=Risikobereitschaft) einer Institution und umfasst folgende Optionen:
    - (gänzliche) Risikovermeidung (z. B. durch Umstrukturierung von Geschäftsprozessen oder des Informationsverbunds)
    - Risikoreduktion/-minimierung durch entsprechende Sicherheitsmaßnahmen
    - Risikotransfer (z. B. durch Outsourcing oder Versicherungen)
    - Risikoakzeptanz-/übernahme (uU inkl Absicherung durch Rücklagenbildung)